

INFORME DE ANÁLISIS DE VULNERABILIDAD - CVE Y CVSS V3.1

INFORMACIÓN GENERAL

- ID de CVE: **CVE-2025-9894**
- Título / Nombre de la vulnerabilidad: Cross-Site Request Forgery (una de mis favoritas como practicante de pentesting)
- Palabra clave utilizada en la búsqueda: CRSF
- Fecha de publicación: 2025-09-27
- Última actualización: 09/29/2025

Descripción y Contexto del Problema

Descripción:

CVE-2025-9894 Detalle

EN ESPERA DE ANÁLISIS

Este registro CVE ha sido marcado para los esfuerzos de enriquecimiento de NVD.

Descripción

El complemento Sync Feedly para WordPress es vulnerable a la falsificación de solicitudes entre sitios en todas las versiones hasta 1.0.1 inclusive. Esto se debe a que falta o es incorrecta la validación de nonce en la función `crsf_cron_job_func`. Esto hace posible que atacantes no autenticados activen la sincronización de contenido desde Feedly, creando potencialmente múltiples publicaciones a través de una solicitud falsificada, siempre que puedan engañar a un administrador del sitio para que realice una acción como hacer clic en un enlace.

Productos y versiones afectadas:

- 1. Complemento Sync Feedly de WordPress en todas sus versiones hasta la 1.0.1.**

El complemento Sync Feedly para WordPress es vulnerable a la falsificación de solicitudes entre sitios en todas las versiones hasta 1.0.1 inclusive. Esto se debe a que falta o es incorrecta la validación de nonce en la función `crsf_cron_job_func`. Esto hace posible que atacantes no autenticados activen la sincronización de contenido desde Feedly, creando potencialmente múltiples publicaciones a través de una solicitud falsificada, siempre que puedan engañar a un administrador del sitio para que realice una acción como hacer clic en un enlace.

La oportunidad

Vectores utilizados para el cálculo (Base Score):

Métricas

CVSS versión 4.0CVSS versión 3.xCVSS Versión 2.0

Los esfuerzos de enriquecimiento de NVD hacen referencia a información disponible públicamente para asociarse cadenas vectoriales. La información CVSS aportada por otras fuentes también lo es mostrado.

CVSS 3.x Gravedad y cadenas vectoriales:

 **CNA:** Valla de palabras

Base Puntuación: 4.3 MEDIO

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:L/A:N

Referencias a avisos, soluciones y herramientas

Al seleccionar estos enlaces, abandonará el espacio web del NIST. Hemos proporcionado información que sea de su interés. No se deben hacer inferencias debido a que puede haber otros sitios que son más apropiados para su propósito. NIST o face expresadas ni estar de acuerdo con ellas los hechos presentados en estos sitios. Ade comercial que pueda mencionarse en estos sitios. Por favor dirija los comentarios s

URL
<https://plugins.trac.wordpress.org/browser/sync-feedly/trunk/sync-feedly.php#L156>

CVSS v3.1 Severity and Metrics:
Base Score: 4.3 MEDIUM
Vector: AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:L/A:N
Impact Score: 1.4
Exploitability Score: 2.8
Attack Vector (AV): Network
Attack Complexity (AC): Low
Privileges Required (PR): None
User Interaction (UI): Required
Scope (S): Unchanged
Confidentiality (C): None
Integrity (I): Low
Availability (A): None

Etiquetas)

Como se aprecia en el cuadro detallado del vector, el puntaje CVSS obtenido (4.3) indica un nivel de severidad **medio**, resultado de una combinación entre una alta explotabilidad (requiere vector de ataque por red, baja complejidad y ningún privilegio previo) y un impacto limitado, ya que afecta principalmente a la integridad de forma leve, sin comprometer la confidencialidad ni la disponibilidad.

Medidas Recomendadas para Mitigar el Riesgo

1. Actualizar el plugin

Si hay una versión más reciente que corrija esta vulnerabilidad, se debe actualizar *inmediatamente* el plugin Sync Feedly a una versión segura (superior a 1.0.1) para eliminar el código vulnerable.

Justificación: la vulnerabilidad ocurre por una función específica (crsf_cron_job_func) con validación de nonce incorrecta; una versión parcheada debería validar correctamente el nonce para prevenir CSRF.

2. Implementar validación de nonce en peticiones sensibles

Modificar el código del plugin (o solicitar al desarrollador) para añadir un nonce válido en todas las funciones críticas de sincronización o cron job.

Justificación: un nonce es un token que ayuda a asegurar que la solicitud proviene de un usuario legítimo y no de una petición forjada, previniendo CSRF.

3. Utilizar un WAF (Web Application Firewall)

Configurar reglas en el WAF para filtrar o bloquear peticiones que intenten activar la sincronización sin un nonce válido o que provengan de fuentes sospechosas.

Justificación: aunque no soluciona el bug, un WAF añade una capa de defensa para detectar y detener intentos de CSRF automatizados o maliciosos antes de que lleguen a la función vulnerable.

4. Capacitar administradores del sitio

Educar a los administradores de WordPress para que no hagan clic en enlaces sospechosos cuando estén autenticados, especialmente si son enlaces que desencadenan acciones importantes como sincronización de contenido.

Justificación: la explotación requiere que un atacante persuada a un administrador para que realice una acción (user interaction), por lo que la formación puede reducir significativamente el riesgo.

Fecha del análisis: 22/11/2025

Nombre del estudiante: Samuel Leonardo Ubrí